

Ethical Perspectives of Cyber Security and Moral Correctness

A Case Study by Sarah Hepburn (EE) and Isaiah Aldiano (CprE)

I. Introduction

Bug bounty programs are often deemed a cybersecurity game-changer, where companies reward ethical hackers for uncovering vulnerabilities before those with malicious intent do. These programs promise collaboration, transparency, and innovation to protect sensitive data [1]. But what happens when hackers uncover flaws without an invitation? This scenario raises complex ethical dilemmas, challenging the very foundations of trust, fairness, and accountability that bug bounty programs strive to uphold.

The gray area of ethical hacking and opportunistic assistance or exploitation is especially apparent in cases where vulnerabilities are disclosed under questionable circumstances. Referring to Uber's controversial handling of its 2016 data breach, this case study dives into the ethical challenges posed by such scenarios. How should companies navigate being transparent while managing risks concerning their reputation? Are hackers who act without authorization advancing security or practicing extortion? And how do companies ensure accountability when legal and ethical standards sometimes conflict?

To address these issues, we have structured this case study as a dynamic conversation that presents diverse perspectives and arguments. This approach allows us to examine competing ethical priorities, ranging from the moral obligations of companies and hackers to the legalities involved. By unpacking these viewpoints, we aim to illuminate the complex dynamic at play between cybersecurity engineering, ethics, and corporate responsibility, highlighting the importance of tackling these challenges to navigate today's evolving digital landscape.

II. Background: The Case of Uber's 2016 Data Breach

In 2016, Uber suffered a major data breach exposing the personal information of around 57 million users and drivers. The hackers, who were not hired by the company, uncovered a vulnerability which resulted in them accessing sensitive data like names, emails, and driver's license numbers. This breach occurred while Uber was already being investigated by the Federal Trade Commission because of a different breach that occurred in 2014 [2]. Instead of reporting the breach, Uber's Chief Information Security Officer, after discussions with around 30 other employees, paid the hackers \$100,000. He had the hackers sign a nondisclosure agreement and disguised the payment as a bug bounty reward to save the company from further embarrassment. The two hackers and Uber's Security Officer faced computer fraud conspiracy charges and criminal obstruction charges, respectively. Both of the hackers pleaded guilty to the charges and

received a reduced sentence for cooperating with the authorities. The Chief Information Security was tried and charged with Misprision of a Felony and Obstruction. His sentence included three years of probation and a \$50,000 fine [5][6].

As with many other cases, the ethical considerations are not simply black and white; there are numerous factors to consider. This case involves a significant number of key parties, both directly and in the broader context of its implications. Evidently, this included Uber's former Chief Security Officer, who managed the response, and the hackers, who acted without authorization but uncovered the flaw. Uber's users and drivers, whose data was compromised, faced potential risks and the company's reputation was also placed in jeopardy. The FTC, and Uber's other leadership also played crucial roles as the company's failure to disclose the breach became a legal and ethical issue. Additionally, the general public was affected, as incidents like this degrade trust in companies to safeguard their data and be transparent if breaches do occur. Such cases also place pressure on the cybersecurity community and the way they handle hackers.

This case highlights the ethical challenges of transparency, corporate responsibility, and the blurred line between ethical hacking and opportunistic exploitation. It raises many critical questions about the actions of the parties involved, leaving a lot to unpack.

III. Our Perspectives

Sarah

At first glance, it was easy to conclude that nothing about this case was handled particularly well. The average individual's moral intuition would likely lead them to believe that most, if not all of the actions taken by the two hackers and the chief information security officer, were 'wrong' and by many normalized standards, they are 'wrong.' However, one with a more experienced ethical perspective would argue that there is a lot more to consider than whether or not their actions were, at first glance, 'right' or 'wrong.' This is why utilizing an ethical theory like deontology would not be effective for analyzing this case. A combined ethical framework incorporating both consequentialism and virtue ethics would provide a better foundation for analyzing this case because it allows for more emphasis to be placed on the outcomes of the decisions made as well as the motives behind these decisions. It also allows for a more humanistic perspective that acknowledges the complexities of human emotions, character traits, and judgement.

Isaiah

The cybersecurity field being a newer profession comes with a large learning curve for every company that is working to increase the security of its products for users to feel safe using. This results in landmark cases that will serve as examples for future security issues to base on. Uber, being an example, provides an example of the fine lines that security professionals and governmental bodies border when it comes to the safety of the public. Observing this case revealed several perspectives to me that makes it hard to pinpoint an ethically "correct" or

“incorrect” side of the situation. I will use the ethical framework of principlism and its four principles to analyze different perspectives of the case. By looking at multiple perspectives of the case and applying the four principles I aim to give insight into the ethical correctness of how each stake holder acted in relationship to the case.

IV. The Debate: A Constructive Argument

To what extent can the hackers’ actions be considered ethical or unethical?

Sarah

The hackers’ actions fall into a gray area, blending both ethical and unethical behavior. From a consequentialist perspective, their actions arguably prevented greater harm. Although they had no authorization to do so, by exposing the vulnerability, they revealed a significant security flaw that Uber might not have identified otherwise. Their discovery of this vulnerability likely prevented it from being discovered by more malicious hackers who could have done much worse and outrightly cyberattacked them. In a way, they helped Uber, as well as Uber’s users and drivers who rely on Uber to keep their data safe. The hackers themselves even benefited temporarily as they received compensation. However, their approach – hacking without authorization – ultimately led to more serious consequences. They ended up facing legal prosecution for their actions and the situation also resulted in the Chief Information Security Officer’s sentencing, the termination of his employment at Uber, and the reputational damage done to the company.

Additionally, from a virtue ethics perspective, their actions raise questions about their character and intent. It is only fair to acknowledge the fact that the hackers could have handled the situation much worse. Their decision to negotiate with Uber instead of maliciously handling the data displayed a certain level of restraint as well as ethical and moral consideration [3]. They chose not to weaponize the breach but sought compensation instead. However, the way in which they sought compensation was self-serving, especially considering the fact that they lacked respect and integrity for hacking Uber in the first place. They also lacked accountability as they initially avoided taking responsibility for their actions and only cooperated because of legal consequences.

Ultimately, the hackers’ actions reside in grayer ethical areas than what one might initially think. The fact that they displayed restraint and consideration during the negotiation process does not erase the fact that they hacked a large company without authorization and accessed the private information of around 57 million users and drivers – they were simply unethical in this case. However, focusing on the results of their actions to determine their ethical standing depends on the answer to two questions: do the ends justify the means of their actions and if so, does the discovery of the security vulnerability affecting 57 million people trump the Chief Information Security Officer’s prosecution, job termination, and the damaged reputation of Uber?

Isaiah

The actions taken by the hackers are difficult to place as an ethical right or wrong. Using a principlism perspective, the hackers were within their autonomy to use Amazon Web Service keys that they gained access to through vulnerabilities in Ubers GitHub repositories. These access keys are meant to stay confidential to protect the safety of a business user's private information. Uber was already vulnerable to malicious attacks at this point, and the hackers were no exception. Through their exploitation they gained access to Uber drivers' private information that could lead to lots of damage if in the wrong hands. Instead, the anonymous hackers report their exploit to Uber and expect \$100,000 in payment in return for not selling driver information. From a beneficence standpoint, this is the best option that financially repays the hackers for not maliciously using driver data while saving Uber from social backlash from their security breach.

The hackers' do not align themselves with the nonmaleficence side of principlism as they do not avoid the harm cause by exploiting Ubers, but they help increase Ubers beneficence by reporting the exploit. This allowed Uber to fix their GitHub repository, saving them from other malicious actors from exploiting their driver's personal data. Justice for the hackers and Uber is spread fairly by their trade of breached information being kept secure through and NDA and the repayment for the report of the exploit to the hackers'.

Ultimately, the hackers, legal proceedings aside, remain completely within their autonomy to expect payment from Uber. Instead of utilizing Uber drivers' private information in a malicious manner they displayed restraint by reporting the "major vulnerability" [5] they had discovered that allowed them access to Ubers database. The payment for their actions was completed under the altered rules of Ubers bug bounty program [2] making their actions as legitimate as any other bug bounty completed.

Was the decision made by Uber's Chief Information Security Officer ethical?

Sarah

Uber's Chief Information Security Officer [CISO] was certainly placed in a situation that forced his ethics to be challenged. If one chose to focus on the outcomes of his actions, they won't find many positive results. Although his attempt to cover up the fact that Uber had been hacked was likely done to protect his company, it made the situation worse than it had to be. Negotiating with the hackers and offering them compensation was simply concealing a crime and essentially presenting a reward to criminals. Considering the fact that Uber was already under investigation by the FTC, this decision likely placed the company in a state of turmoil with the FTC in which they weren't necessarily considered to be trustworthy anymore. Uber users and drivers' trust in them as well as the public's trust in them was also degraded – broader questions were raised about the validity of bug bounty programs, what other illegal coverups are happening, and whether or not big companies can be trusted with user data anymore. The most unfortunate part is that in his supposed efforts to protect the company, the CISO ended up embarrassing the

company more as they were caught trying to cover up a breach while they were already being investigated for a breach. Arguably, considering that the outcomes of the situation were going to be negative for the company either way, the most important thing to consider is whether it would have been better if the public knew or didn't know about the breach. The ethical thing to do was to inform them about the situation.

On the other hand, one must still consider the intentions of the CISO's actions and the fact that he is still a human being that was placed in a difficult situation. It is admirable that he displayed such loyalty and consideration for his company. His company was already embarrassed by the prior breach and he, as head of information security of Uber, shared a large part of that embarrassment. Therefore, it is reasonable that he had already seen his company suffer and didn't want that to become even worse. As a lot of individuals do, he likely did what he thought was best while in a state of stress and panic. However, while he did display loyalty, care and consideration, he was also fairly selfish. He exploited the bug bounty system – a system that already faced some ethical scrutiny – and used it to cover up a crime which was not a responsible thing to do. Additionally, he simply failed to act with honesty and accountability by concealing attempting to conceal the breach. He put the interests of his company's reputation and his own reputation above the millions of people that the breach affected – people that deserved to know that hackers had access to their data. It is fair to compare this situation to the scenario of a crime happening to someone and them choosing not to report it, which is ultimately their choice [4]. However, the breach didn't just happen to Uber, it happened to their millions of users also and there was no consideration for them. The decision was unethical to a great extent.

Isaiah

Joe Sullivan, Ubers Chief Information Security Officer during this case, was given hard situation to maneuver during his time at the company. He was hired on after the hackers had already gained access to Ubers database [5]. After being contacted by the hackers and requesting payment for their findings, Sullivan decided to cover up the hackers' actions via the Ubers bug bounty program. As the CISO, Sullivan is tasked with being the deciding body on cases that will impact the integrity of Ubers users' data. Though he has a security team to work with, his authority gives him the ability to make a recommendation to the CEO as he sees best for the company. The beneficence that Sullivan decided to carry on by covering up the large security breach via the bug bounty program must've outweighed the maleficence onto his team and the company that further investigation by the FTC or DOJ would've brought. Furthermore, Sullivan aligned with beneficence by compensating the hackers' the requested amount of \$100,000 in return for their cooperation and later signing of non-disclosure agreements [2].

Justice for everyone was spread evenly among all parties involved. The hackers received payment for their restraint of malicious data usage and reporting the data breach, and Uber was maintaining its image to stakeholders and Uber drivers by fixing the breach and, per NDA, saving all data. Sullivan, however, didn't align with non-maleficence when working with the

FTC. His actions to cover up the data breach were clearly in violation with the FTC's Breach Notification Rule where they must notify impacted users and the FTC of a data breach. His actions followed suit with the majority of principlism's framework, though that doesn't automatically categorize his actions as ethically correct. Via the principlism framework, Sullivan's decision seems to fall in an ethical gray area where his actions aligned with his autonomy, beneficence of others, and justice for all but clearly disregarded non-maleficence for the governmental bodies that regulate these situations for the benefit of the consumer.

V. Common Ground: Shared Beliefs

While our perspectives differ in analyzing the actions of the hackers and Uber's CISO, we both acknowledge that there were undeniable unethical aspects in both cases. The hackers' unauthorized breach and the CISO's decision to conceal it highlight certain lapses in ethical judgement. Interestingly, our chosen ethical frameworks, virtue ethics and consequentialism, and principlism on the other, share overlapping concerns, particularly concerning justice and the ethical implications of the outcomes of the situation. Additionally, we both agree that the Department of Justice's heavy involvement may not have been the most effective approach to handling the case. Cybersecurity threats possess a certain level of complexity, and this ethical dilemma might have been better handled by the cybersecurity professionals. We feel that experts with knowledge and experience could offer judgement coming from a more informed perspective than a jury of individuals that are unfamiliar with the technicalities of these issues.

VI. Recommendations

If you were the hackers, how might you have approached the situation differently?

Sarah

If I were the hackers, assuming that I still ended up hacking Uber, I would have reported the vulnerability through an authorized channel, such as Uber's bug bounty program, without attempting to exploit it first. From a virtue ethics perspective, this approach would demonstrate integrity, accountability, and respect for boundaries to a certain extent – virtues that the hackers initially lacked. Additionally, a consequentialist perspective supports this different approach because it avoids unnecessary legal problems and reputational harm done to the company while also assisting the company in preventing further exploitation of the vulnerability. This alternative approach balances moral character with better outcomes for the stakeholders involved.

Isaiah

From the perspective of the hackers, I would've avoided the exploitation of Uber's private databases. Time would be of the essence since other malicious actors could find the same exploit, but proper documentation and professionalism are a key aspect of reporting such large exploit. Through a principlism point of view, it would be hard to align any actions taken with all

four of the principles it describes. However, I would try to align with the non-maleficence and beneficence principles of principlism by reporting the found exploits through proper channels without going through with any actions that steal the private data. In comparison to the actions the hackers made, these actions would produce a more just outcome for everyone involved.

As Uber's Chief Information Security Officer, how could you have managed the breach in a manner that upheld ethical standards?

Sarah

If I were the CISO, I would have immediately reported the breach to the appropriate authorities and informed Uber's users and drivers about the situation. From a virtue ethics perspective, this approach would demonstrate honesty, accountability, and respect for the individuals whose data was compromised by the breach. By being transparent about the situation, I would be upholding ethical standards that the public and the company would expect from a leader in such a high position in the company. These actions would also align with consequentialism by prioritizing transparency and maintaining trust, which could minimize reputational damage in the long run. While this approach might still have resulted in some scrutiny from the FTC and/or the public, it would have shown that Uber was taking responsibility and addressing the issue. This could have, at the least, preserved public trust, maintained the integrity of the company and prevented the ethical and legal complications that arose from the concealment breach.

Isaiah

As CISO, it would be important that I consider the four principles closely. To respect the autonomy of Uber's drivers I would have notified all the appropriate governmental bodies that deal with breaches of this magnitude. From there a decision would be made by myself and others to decide how to publicly continue despite current investigations already taking place. This would involve notifying the impacted drivers and informing them how to proceed with further protecting their information. To align with beneficence, it would be best to isolate the incident and mitigate any further breaches spreading from the compromised system. To avoid causing further harm and following non-maleficence, the decision made by government bodies and Uber executives would involve planning a public announcement of the breach. This would also involve working with law enforcement and other cybersecurity experts to find the malicious actors and ensure no additional breaches occur. To ensure justice is spread fairly there would be no differentiation of Uber driver remediation. All impacted users would receive equal reconciliation irrespective of geographical location, driver status, etc. This would be paired with our public announcement that acknowledges Uber's faults and displays steps we will take to make right by the users. More than likely, internal investigations would be conducted to determine any negligence or oversights that lead to the breach. By applying the four principles of principlism the entire situation could've ended much differently with a more favorable outcome.

VII. Our Final Thoughts: Conclusion

Overall, the ethical dilemmas presented in Uber's data breach case reveal the complexities of responsibility, technology and making decisions. The choices made by both the hackers and Uber's Chief Information Security Officer highlight the significant contrast between short-term gains and long-term consequences. Although we approached the case using different ethical frameworks – virtue ethics, consequentialism, and principlism – our analysis revealed that there were a number of unethical aspects present, regardless of the framework used. The case serves as a reminder that, although not always, ethical lapses in judgement can have severe consequences – consequences that we likely don't want but don't always see coming.

Ultimately, as the wise proverb states, "there is nothing new under the sun." This case did not introduce any entirely new ethical or cybersecurity challenges – in fact, there is a chance that this has happened with many other companies but was never revealed. Instead, it highlights the consistent issues of integrity, accountability, and transparency that have persisted over time as technology continues to evolve. Every time a case similar to this happens, we are reminded of the need to foster a stronger ethical culture in the cybersecurity and corporate communities. The only relevant question left is: how long will we continue to overlook these issues before we take meaningful action?

References

- [1] Lau, Jason. "Bug Bounty Programs: Why Companies Need Them Now More than Ever." CSO Online, 10 Dec. 2024, www.csoonline.com/article/3619983/bug-bounty-programs-why-companies-need-them-now-more-than-ever.html.
- [2] Belanger, Ashley. "Uber Exec Accused of Disguising Data-Breach Extortion as "Bug Bounty."" Ars Technica, 9 Sept. 2022, arstechnica.com/tech-policy/2022/09/uber-exec-accused-of-disguising-data-breach-extortion-as-bug-bounty/.
- [3] University, Santa Clara. "Unavoidable Ethical Questions About... Hacking." Wwww.scu.edu, www.scu.edu/ethics/focus-areas/internet-ethics/resources/unavoidable-ethical-questions-about-hacking/.
- [4] Gennaro, Michael. "Former Uber Security Head Argues for New Trial on Obstruction of Justice Conviction." Courthousenews.com, 2024, www.courthousenews.com/former-uber-security-head-argues-for-new-trial-on-obstruction-of-justice-conviction/.

[5] Wright, Rob. "The Uber Data Breach Cover-Up: A Timeline of Events." SearchSecurity, 31 Aug. 2020, www.techtarget.com/searchsecurity/news/252488361/The-Uber-data-breach-cover-up-A-timeline-of-events.

[6] "Northern District of California | Former Chief Security Officer of Uber Sentenced to Three Years' Probation for Covering up Data Breach Involving Millions of Uber User Records | United States Department of Justice." www.justice.gov, 5 May 2023, www.justice.gov/usao-ndca/pr/former-chief-security-officer-uber-sentenced-three-years-probation-covering-data.